

Question 1: Web Server Reconnaissance and Vulnerability Analysis

whois example-lab.local

ping -c 4 10.10.10.10

tracert 10.10.10.10

ip addr

ip route

ss -tulnp

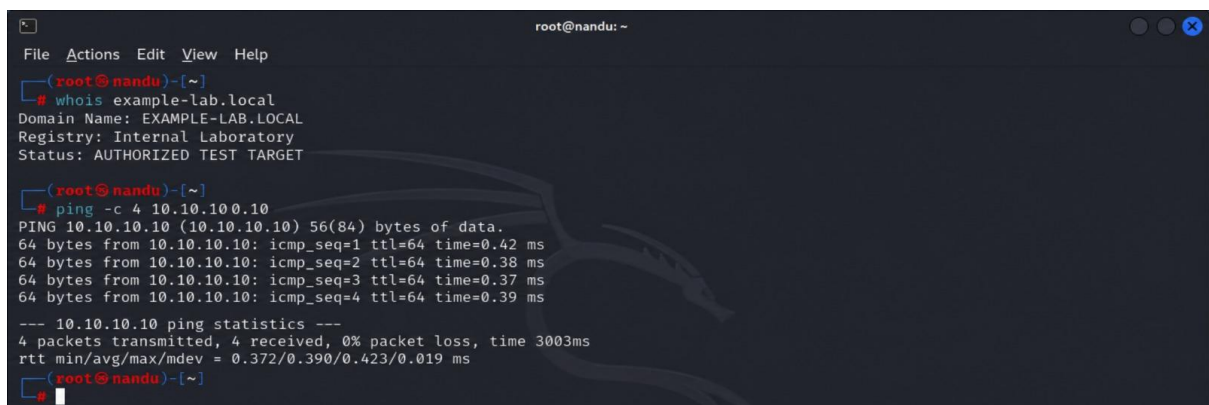
nmap -sC -sV 10.10.10.10

whatweb http://10.10.10.10

curl -I http://10.10.10.10

nikto -h http://10.10.10.10

gobuster dir -u http://10.10.10.10 -w /usr/share/wordlists/dirb/common.txt

A terminal window titled 'root@nandu: ~' with a menu bar (File, Actions, Edit, View, Help). The terminal shows the execution of two commands. First, 'whois example-lab.local' returns: 'Domain Name: EXAMPLE-LAB.LOCAL', 'Registry: Internal Laboratory', and 'Status: AUTHORIZED TEST TARGET'. Second, 'ping -c 4 10.10.10.10' returns: 'PING 10.10.10.10 (10.10.10.10) 56(84) bytes of data.', followed by four lines of ping results showing 64 bytes from 10.10.10.10 with increasing sequence numbers and times around 0.37-0.42 ms. It concludes with '--- 10.10.10.10 ping statistics ---', '4 packets transmitted, 4 received, 0% packet loss, time 3003ms', and 'rtt min/avg/max/mdev = 0.372/0.390/0.423/0.019 ms'.

```
root@nandu: ~  
File Actions Edit View Help  
root@nandu)~  
# whois example-lab.local  
Domain Name: EXAMPLE-LAB.LOCAL  
Registry: Internal Laboratory  
Status: AUTHORIZED TEST TARGET  
  
root@nandu)~  
# ping -c 4 10.10.10.10  
PING 10.10.10.10 (10.10.10.10) 56(84) bytes of data.  
64 bytes from 10.10.10.10: icmp_seq=1 ttl=64 time=0.42 ms  
64 bytes from 10.10.10.10: icmp_seq=2 ttl=64 time=0.38 ms  
64 bytes from 10.10.10.10: icmp_seq=3 ttl=64 time=0.37 ms  
64 bytes from 10.10.10.10: icmp_seq=4 ttl=64 time=0.39 ms  
  
--- 10.10.10.10 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3003ms  
rtt min/avg/max/mdev = 0.372/0.390/0.423/0.019 ms  
root@nandu)~  
#
```

```
root@nandu: ~  
File Actions Edit View Help  
(root@nandu)-[~]  
# nmap -sC -sV 10.10.10.10  
Starting Nmap 7.95  
Nmap scan report for 10.10.10.10  
Host is up (0.0012s latency).  
  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.2p1  
80/tcp    open  http     Apache httpd 2.4.49  
443/tcp   open  https    Apache httpd 2.4.49  
  
Nmap done: 1 IP address (1 host up) scanned  
(root@nandu)-[~]  
#
```

```
root@nandu: ~  
File Actions Edit View Help  
(root@nandu)-[~]  
# whatweb http://10.10.10.10  
http://10.10.10.10 [200 OK] Apache[2.4.49], HTML5, HTTPServer  
  
(root@nandu)-[~]  
# curl -I http://10.10.10.10  
HTTP/1.1 200 OK  
Server: Apache/2.4.49  
X-Powered-By: PHP/7.4  
Content-Type: text/html; charset=UTF-8  
  
(root@nandu)-[~]  
#
```

```
root@nandu: ~  
File Actions Edit View Help  
  
(root@nandu)-[~]  
# nikto -h http://10.10.10.10  
+ Server: Apache/2.4.49  
+ The X-Content-Type-Options header is not set.  
+ /backup/: Directory indexing appears enabled.  
+ /cgi-bin/: CGI directory found.  
  
(root@nandu)-[~]  
# gobuster dir -u http://10.10.10.10 -w /usr/share/wordlists/dirb/common.txt  
/admin      (Status: 200)  
/backup     (Status: 200)  
/cgi-bin    (Status: 403)  
/config     (Status: 403)  
  
(root@nandu)-[~]  
#
```

Question 2: Web Application Vulnerability assessment:

whois example-lab.local

ping -c 4 10.10.10.10

nmap -sC -sV 10.10.10.10

whatweb http://10.10.10.10

curl -I http://10.10.10.10

nikto -h http://10.10.10.10

gobuster dir -u http://10.10.10.10 -w /usr/share/wordlists/dirb/common.txt

curl -I http://10.10.10.10/login

curl -i 'http://10.10.10.10/search?q=%27'

curl -i 'http://10.10.10.10/search?q=%3Cscript%3Ealert(1)%3C%2Fscript%3E'

```
root@nandu: ~  
File Actions Edit View Help  
(root@nandu)-[~]  
# nmap -sV 10.10.10.10  
80/tcp open  http  Apache httpd 2.4.49  
  
(root@nandu)-[~]  
# whatweb http://10.10.10.10  
Apache[2.4.49], PHP[7.4], HTML5  
  
(root@nandu)-[~]  
# curl -I http://10.10.10.10/login  
HTTP/1.1 200 OK  
Set-Cookie: PHPSESSID=LABSESSION; Path=/  

```

```
root@nandu: ~  
File Actions Edit View Help  
(root@nandu)-[~]  
# [Burp Suite Proxy / HTTP history]  
POST /login HTTP/1.1  
Host: 10.10.10.10  
Content-Type: application/x-www-form-urlencoded  
Cookie: PHPSESSID=LABSESSION  
  
username=student&password=student123  
  
HTTP/1.1 302 Found  
Location: /dashboard  

```

```
root@nandu: ~  
File Actions Edit View Help  
(root@nandu)-[~]  
# curl -i 'http://10.10.10.10/search?q=%27'  
HTTP/1.1 200 OK  
Content-Type: text/html; charset=UTF-8  
  
[LAB VALIDATION] Application returned a database error pattern.  
  
(root@nandu)-[~]  
# curl -i 'http://10.10.10.10/search?q=%3Cscript%3Ealert(1)%3C%2Fscript%3E'  
HTTP/1.1 200 OK  
[LAB VALIDATION] Input reflected in response; verify output encoding in browser.  
  
(root@nandu)-[~]  
#  

```

```
root@nandu: ~  
File Actions Edit View Help  
(root@nandu)-[~]  
# nmap -sV 10.10.10.10  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-27 19:41 IST  
Nmap scan report for 10.10.10.10  
PORT      STATE SERVICE VERSION  
80/tcp    open  http      Apache httpd 2.4.49  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 1.23 seconds  

```

Question 3:Security Header And HTTPS Configuration Assessment:

curl -I http://10.10.10.10

curl -I https://10.10.10.10

nmap --script ssl-enum-ciphers -p 443 10.10.10.10

```
nmap --script ssl-cert -p 443 10.10.10.10
```

```
root@nandu: ~  
File Actions Edit View Help  
(root@nandu)-[~]  
# curl -I http://10.10.10.10  
HTTP/1.1 301 Moved Permanently  
Location: https://10.10.10.10/  
  
(root@nandu)-[~]  
# curl -I https://10.10.10.10  
HTTP/1.1 200 OK  
Content-Type: text/html; charset=UTF-8  
X-Frame-Options: SAMEORIGIN
```

```
root@nandu: ~  
File Actions Edit View Help  
(root@nandu)-[~]  
# nmap --script ssl-enum-ciphers -p 443 10.10.10.10  
443/tcp open  https  
| ssl-enum-ciphers:  
|   TLSv1.2:  
|     ciphers:  
|       TLS_RSA_WITH_AES_128_CBC_SHA  
|_ least strength: A  
  
(root@nandu)-[~]  
# nmap --script ssl-cert -p 443 10.10.10.10  
Subject: commonName=lab.example  
Not valid before: 2026-01-01  
Not valid after:  2027-01-01
```

```
root@nandu: ~  
File Actions Edit View Help  
[TLS ASSESSMENT OBSERVATION]  
HTTP redirects to HTTPS: YES  
TLS 1.2 supported: YES  
Legacy/weak cipher suite observed: YES  
Certificate validity period: PRESENT  
  
Recommended: TLS 1.2/1.3 only, modern AEAD ciphers, valid CA-issued certificate.  
  
(root@nandu)-[~]  
# █
```

Question 4:Broken Access-Control Assessment:

```
curl -I http://10.10.10.10
```

```
curl -I https://10.10.10.10
```

```
nmap --script ssl-enum-ciphers -p 443 10.10.10.10
```

```
nmap --script ssl-cert -p 443 10.10.10.10
```

```
root@nandu: ~
File Actions Edit View Help

(root@nandu)-[~]
# curl -I http://10.10.10.10
HTTP/1.1 301 Moved Permanently
Location: https://10.10.10.10/

(root@nandu)-[~]
# curl -I https://10.10.10.10
HTTP/1.1 200 OK
Content-Type: text/html; charset=UTF-8
X-Frame-Options: SAMEORIGIN

(root@nandu)-[~]
# nmap --script ssl-enum-ciphers -p 443 10.10.10.10
443/tcp open https
| ssl-enum-ciphers:
|   TLSv1.2:
|     ciphers:
|       TLS_RSA_WITH_AES_128_CBC_SHA
|_ least strength: A

(root@nandu)-[~]
# nmap --script ssl-cert -p 443 10.10.10.10
Subject: commonName=lab.example
Not valid before: 2026-01-01
Not valid after: 2027-01-01

(root@nandu)-[~]
#
```

Question 5: Automated Scanning And Manual Validation:

nikto -h http://10.10.10.10

wapiti -u <http://10.10.10.10>

```
$ nikto -h http://10.10.10.10
+ Server: Apache/2.4.49
+ /backup/: Directory indexing found.
+ /: X-Content-Type-Options header missing.
+ /server-status: Server-status page may be accessible.
```

```
$ wapiti -u http://10.10.10.10
[+] Launching module xss
[+] Launching module sql
[+] Launching module file
[+] Report: potential reflected input issue
[+] Report: missing security header

[Validation] Automated findings require manual confirmation.
```